MDPI

Article

Identifiability Before MSSP Portfolio Decisions: A Source-Locked Industrial Audit of Priority Scores, Launch Stages, and Financial Aggregates

Muhammad Emran [1,*] and Ghassan Malkawi [1]

[1] Faculty of Computer Information Science, Higher Colleges of Technology, Al Ain, United Arab Emirates; memran@hct.ac.ae (M.E.); gmalkawi@hct.ac.ae (G.M.)
* Correspondence: memran@hct.ac.ae

Highlights

Contribution to systems science

- Links source capabilities, consolidated service packages, staged launches, priority scoring, and financial aggregates as a coupled planning-decision system.
- Specifies source-consistency and claim-identifiability checks before optimization is justified.

Main findings and implications

- All 51 source capabilities map to 25 packages, but equal package labels conceal distinct component states, and prioritization weights are missing.
- Twelve family-year totals leave 45 conditional revenue-allocation dimensions unresolved; governance decisions require additional evidence.

Abstract

Managed security service providers (MSSPs) often plan new offerings through disconnected catalogues, scorecards, schedules, and financial sheets. We examine whether one prospective industrial MSSP roadmap supports service-level decisions claimed from those artifacts. A fixed company archive contained 25 entries; nine selected analytical spreadsheet/PDF files and one contextual approval record were audited using source-typed claim-identifiability and consistency checks. The final documents agree on five focus areas, 25 consolidated packages, and a 12/8/5 year-by-year launch plan. However, the detailed catalogue has 51 capabilities versus a hard-coded 49 summary; all 51 map exactly once to packages, while equal package labels conceal different component statuses. Five-criterion priority scores lack documented weights, so the scorecard alone cannot uniquely recover the narrative's firewall priority. One component is scheduled later than its package, and five additional packages show later maturity signals. Twelve family-year totals constrain 57 service-year revenue unknowns, leaving 45 free dimensions under the declared additive model. Release prerequisites are documented, but completion evidence is not. The study contributes a reproducible, conflict-aware evidence-before-optimization audit and minimum-evidence register, not a new optimization algorithm or evidence of operational failure or realized performance.

Keywords: managed security services; service portfolio; evidence sufficiency; decision identifiability; financial identifiability; cybersecurity governance

Received:
Accepted:
Published:

Copyright: © 2026 by the authors. Manuscript prepared for review; not submitted or published. Reuse license not yet assigned.

1. Introduction

Managed security service providers (MSSPs) increasingly package operational, governance, identity, data-security, and human-risk capabilities into recurring service portfolios. This creates a familiar optimization question—which services should be launched, when, and with what resources—but also a logically prior evidence question: *does the planning record identify the facts required by the decision being optimized?*

Service-portfolio research provides structures for representing and evaluating portfolios [1,2]; heterogeneous service-repository integration addresses correspondences and representational conflicts [3]; new-service-development research separates service identification, modelling, implementation, and commercialization [4,5]; and robust portfolio methods already address incomplete costs and interdependencies [6,7]. MSSP economics and information-security outsourcing are established topics [8,9]. Likewise, sensitivity to criterion weights is established in multi-criteria decision analysis (MCDA) [10]. We therefore do not propose a new optimizer, maturity index, or MCDA method.

The narrower problem is that commercial planning artifacts operate at different levels of granularity. A detailed capability may be collapsed into a package; a package may inherit a single status and launch year; five focus areas may receive ordinal score vectors without an explicit aggregation rule; financial forecasts may be available only by family; and key performance indicator (KPI) rows may contain planned targets rather than observations. If these layers are treated as interchangeable, a roadmap can appear quantitatively precise while a service-level claim remains underdetermined.

From a systems perspective, the object of study is the *coupled planning-decision architecture*, not the accuracy of an isolated spreadsheet. Its documented layers link named capabilities to packages, package labels to staged availability, criterion scores to portfolio priorities, and family-level resources and revenue to proposed commercial choices. A cross-layer inference is admissible only when its source unit, timing and evidentiary role survive that transition. This is an analysis of *documented decision dependencies*; it neither models actual operational feedback loops nor measures organizational or cybersecurity performance.

We examine this problem in a prospective MSSP transformation case. The parent archive contains 25 entries: 23 material entries and two export-error text records. Two pairs of material entries are byte-identical copies, leaving 21 distinct material payloads. Nine selected source files form the quantitative and cross-format audit, while one distinct weekly reflection provides a contextual approval-status check. The source-admission and exclusion summary appears in Appendix A; the exact-path audit ledger remains restricted to authorized investigators. These artifacts document successive planning drafts, not repeated company deployments. Draft-2 and Draft-3 do not represent observed before/after performance; they are successive planning versions. Draft-3 is the primary analytical source and contains a 51-capability catalogue, a 25-package consolidation, five focus areas, a three-year roadmap, resource/KPI models, and a five-family financial scenario.

The study asks four research questions:

1. **RQ1 – Source and aggregation identifiability.** Does the planning record consistently identify the service universe and preserve the component information required by package-level claims?
2. **RQ2 – Decision-rule and stage identifiability.** Do the prioritization scorecard and launch-year artifacts determine the claimed priority/stage decisions without introducing an unstated rule?
3. **RQ3 – Financial identifiability.** Can family-level forecasts identify service-level revenue or the economic consequence of delaying a package/component?

4. **RQ4 – Operational evidence.** Which launch/readiness claims are supported by planning evidence, and which require observed release, pilot, service-level agreement (SLA), or acceptance records?

The contribution is a source-locked industrial case and a claim-specific audit workflow with explicit consistency and interpretation gates. Repository reconciliation, claims–arguments–evidence, and partial identification are established prior art; novelty is not asserted for those general principles. The proposed extension is the combination of their decision-relevant tests with verifiable source-to-claim witnesses in one prospective MSSP planning archive, not a demonstrated performance improvement over existing methods. Where two interpretations are both consistent with the supplied evidence but yield different service-level decisions, the appropriate output is not identified, rather than an invented weight, allocation, readiness state, or counterfactual.

2. Related Work and Positioning

2.1. Service portfolios, incomplete information, and decision rules

Kohlborn et al. conceptualize service portfolio management through goals, tasks, governance, methods, and enablers [1]; Comerio et al. formalize a repository-oriented service portfolio and design metrics [2]. More directly, Batini and Comerio address integration of heterogeneous service repositories by identifying correspondences among service representations [3]. Our 51-to-25 check therefore cannot claim to invent cross-repository reconciliation: it asks which *decision-specific* facts remain recoverable after source-authored consolidation. Lin and Hsieh distinguish service identification from later implementation and commercialization activities [4]. These frameworks motivate a key distinction in the present case: being listed in a portfolio is not equivalent to having the evidence required to claim operational release.

Incomplete information is not new to portfolio decision support. Liesiö et al. develop robust portfolio models with incomplete costs and project interdependencies [6], while Tavana et al. apply hybrid portfolio selection in a cybersecurity-industry context [7]. MCDA rankings are also known to depend on criterion weights and their sensitivity [10]. Our scorecard analysis is therefore a case-specific identifiability diagnostic, not a new weighting method.

2.2. How the present study extends prior work

Table 1 positions the contribution as an upstream complement rather than a replacement for established portfolio, MSSP, and quality-assurance methods. The common thread is that prior methods need a decision object—a service, project, cost, score, contract, or measure—whose meaning is sufficiently specified. The present study tests that precondition directly in a multi-artifact industrial roadmap.

Table 1. Closest prior work and how the present study continues it. The comparison concerns decision scope, not study quality.

Prior study/strand	Established contribution	How the present study builds on it
Kohlborn et al. (2009) [1]	Framework for service-portfolio goals, governance, tasks, methods, and enablers.	Adds a pre-decision test: are the service-level facts needed by a portfolio decision actually identified in the planning evidence?
Comerio et al. (2015); Batini and Comerio (2016) [2,3]	Portfolio repositories, decision metrics, and reconciliation of heterogeneous service descriptions.	Uses existing reconciliation principles as an input integrity check, then tests whether grouped source labels determine a *specified component-level decision predicate*. No new repository-integration method is claimed.
Lin and Hsieh (2011); Menor and Roth (2008) [4,5]	Separate service identification/design from implementation and commercialization capabilities.	Turns that distinction into an evidence gate: catalogue inclusion and planned launch are not treated as operational readiness without release/measurement evidence.
Liesiö et al. (2008) [6]	Robust portfolio choice with incomplete cost information and project interdependencies.	Moves one step upstream by testing whether service-level financial quantities are identifiable before robust optimization or scenario analysis.
Tavana et al. (2019) [7]	Multi-criteria/fuzzy portfolio selection in a cybersecurity-industry case.	Audits whether criterion aggregation, weights, and service-level inputs are documented before a numerical ranking is treated as reproducible.
Gupta and Zhdanov (2012); Cezar et al. (2017); Wu et al. (2017) [8,9,11]	MSSP economics, network structure, outsourcing, contracts, investment, and interdependent risk.	Shifts inside the provider and asks whether its own roadmap identifies the service scope, stage, and economics required for service-level commercial claims.
Powell et al. (2008); Poon et al. (2024) [12,13]	Spreadsheet errors and QA are established risks in operational decision support.	Uses spreadsheet defects only when they change evidence lineage or claim admissibility; no new spreadsheet-auditing method is claimed.
Dawson et al. (2026) [14]	Cybersecurity decisions are shaped by uncertainty, information asymmetry, and limited empirical guidance.	Provides a concrete source-to-claim audit showing which MSSP roadmap claims are recoverable and which require an additional rule or operational evidence.
GSN/SACM; Mohamad et al. (2021, 2024); Viger et al. (2026) [15–19]	Structured claims–evidence reasoning; empirical evidence-management gaps across six firms; identification of previously undocumented defeaters in a complex assurance case.	Does not invent missing-evidence diagnostics or defeaters. Tests *four typed claim dispositions* against planning records, with explicit witnesses and limits, without asserting security assurance or operational failure.
Manski (2005) [20]	Identification regions characterize conclusions supported without stronger assumptions.	Uses non-unique service-revenue allocations as a finite algebraic witness, not a population identification result or a new statistical-identification theorem.

These comparisons identify scientific ancestry, *not* empirical superiority to prior methods. In particular, the presence-only contrast in Table 6 is deliberately weaker than a full

assurance-case review, OSCAL assessment, or robust portfolio model. Taken together, these studies define the foundation on which the present case builds. Service-portfolio and new-service-development work explains what must be managed; robust and multi-criteria portfolio models explain how choices can be optimized under uncertainty; MSSP research explains economic and sourcing incentives; spreadsheet and security-measurement research explains why evidence quality matters. Our narrower addition is an *evidence-before-optimization* gate: before those methods are used to justify a more granular service decision, test whether the admitted source artifacts actually identify the required input or claim at that granularity.

2.3. Assurance arguments and identification sets: the closest methodological precedents

Security assurance cases explicitly relate claims, assumptions, arguments, and supporting evidence; the Goal Structuring Notation and OMG Structured Assurance Case Metamodel already formalize this family of reasoning [15,16]. A systematic review by Mohamad et al. examines security assurance cases and their practical validation limitations [17]. Subsequent interviews in six safety-critical organizations document the challenges of identifying and managing security evidence [18]; an assurance-case study of the Large Hadron Collider demonstrates that a structured argument can expose previously undocumented defeaters [19]. These are materially close precedents: neither missing-evidence recognition nor structured rebuttal is novel here. Thus the present paper does *not* claim to invent evidence sufficiency, provenance, or claim–evidence linkage. Its narrower output comprises source-specific, machine-checkable decision dispositions for ranked priorities, launch stages, and service-revenue inferences in one MSSP planning archive.

Partial-identification research likewise distinguishes information from identifying assumptions and uses sets of admissible values rather than imputing a convenient point estimate [20]. Our finite documentary interpretation set borrows that logic as a methodological analogy; it is not an econometric estimator or a proof of population identification. The added operational requirements here are typed version/scope alignment, nonempty consistency testing, explicit counterexample witnesses, and withholding operational outcomes for which only plans are present.

2.4. Security evidence and measurement

OSCAL distinguishes implementation descriptions from assessment results. Its control-mapping model already represents typed inter-document relationships and provenance [21]. Its Assessment Results model separately represents assessment scope, actions, observations, findings, timestamps, and supporting evidence [22], while implementation descriptions can represent states such as planned, partial, or implemented [23]. NIST SP 800-55 emphasizes measure definition, documentation, data quality, testing, validation, and reporting [24,25]. NIST IR 8477 and SP 1347 provide additional discipline for documentary mappings and informative references [26,27]. These are prior art for evidence semantics. Our contribution is to connect that discipline to an industrial service-roadmap decision and test, claim by claim, whether the planning artifacts actually identify the quantity or state being asserted.

2.5. Spreadsheet quality assurance and cybersecurity decision uncertainty

Spreadsheet faults, testing, and quality assurance are established research areas. Powell et al. review the prevalence and consequences of spreadsheet errors in decision support [12], and Poon et al. survey spreadsheet quality assurance across the spreadsheet life cycle [13]. The present study therefore does not claim novelty for detecting a broken reference, stale helper count, or hard-coded value. Those observations matter only insofar as they alter the evidence available for a cross-artifact service-level claim.

Recent cybersecurity decision-making research likewise emphasizes uncertainty, limited empirical guidance, and information asymmetries in organizational decisions [14]. Our case contributes a reproducible source-to-claim test at a specific decision boundary: before a roadmap score, launch year, or financial aggregate is used to support a more granular service decision, can that claim be uniquely recovered from the admitted evidence?

2.6. From established methods to source-testable claims

Table 2 identifies the precise audit operation inherited from earlier research, alongside what is actually demonstrated in this case. This distinction is important: a citation to an established method is not evidence that the present work exceeds its accuracy, efficiency, or external validity.

Table 2. Methodological lineage tied to bounded source tests. Reported results are within-case witnesses, not a head-to-head performance benchmark.

Existing methodological basis	Adopted audit operation	Observable case witness / boundary
Service-repository reconciliation [2,3]	Fix source version and mapping unit; test whether aggregation retains necessary detail.	51 exact capability-to-package links; S06/S07 share one aggregate label but differ on the declared component predicate. This is not a new matching algorithm.
Robust portfolio and MCDA [6,7]	Expose choice-rule/weight assumptions before using a numeric priority.	Three hypothetical weight vectors within the explicitly diagnostic weighted-sum class yield different winners; the independently documented Firewall narrative remains a separate planning choice.
Partial identification [20]	Exhibit distinct admissible allocations with identical observed aggregates.	Two normalized positive revenue allocations; 57 unknowns and rank 12 under the specified additive model. No econometric or causal inference follows.
Assurance cases, evidence management and OSCAL [17,18,22]	Type each claim by scope, evidence role and required observation; hold absent-outcome claims.	The four-way claim disposition separates contradictory totals, non-unique inputs, source facts and missing release evidence. It does not certify a service.

3. Materials and Methods: Case Material and Source Lock

The immutable archive has SHA-256 `2165f8a199bb605ca6a68f96323019bee57bc4599b2279b0b3b9b08e043f7ce6`. Nine primary analytical files were independently hash-matched to the source manifest; a distinct weekly reflection was separately matched for the approval-status boundary. Table 3 summarizes analytical roles. Appendix A reports de-identified source IDs, archive-selection counts, and exclusion reasons; a restricted ledger preserves the exact source entry paths.

Table 3. Evidence layers and admissible interpretation.

Layer	Admitted evidence	Not admitted
Draft-2 planning	Earlier 10-area portfolio, five-market scope, Year-3 ARR scenarios, pilot logic	Historical performance or growth relative to Draft-3
Draft-3 final workbook	51 capability rows, focus score vectors, years/statuses, KPI targets, family financials, resource assumptions	Actual delivery, observed demand, realized profit
25-service consolidation	25 package IDs, 12/8/5 planned years, aggregate labels, exact capability mapping	Commissioning acceptance or full-scope maturity
Final report/deck	Final five focus areas, roadmap, exit criteria, selected accounting convention, launch prerequisites	Evidence that exit criteria were achieved

Draft-2 and Draft-3 change the decision universe. Draft-2 models ten new areas across a five-market scope and frames its financial scenario as Year-3 annual recurring revenue (ARR). Draft-3 reduces the final focus areas to five, changes the market scope, consolidates detailed services into 25 packages, and reports cumulative three-year revenue. Their numerical difference is therefore not an observed business-growth estimate.

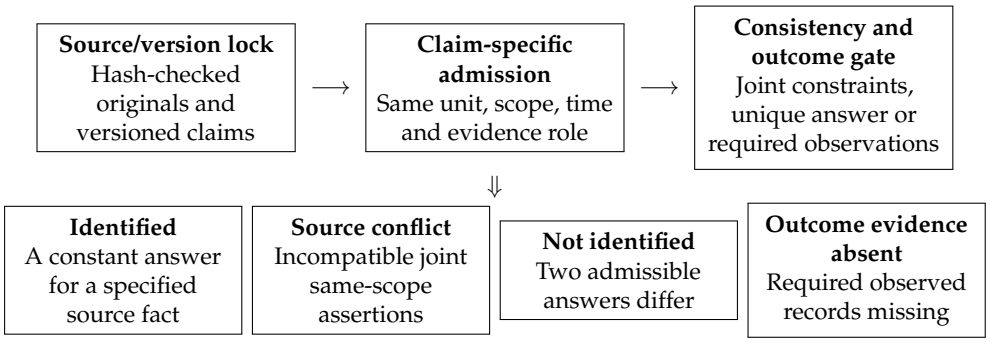


Figure 1. Claim-specific evidence admission and four distinct documentary dispositions. The classes distinguish source contradiction, admissible alternative interpretations and missing observed outcomes; missing evidence does not establish service failure.

4. Claim-Identifiability Audit Method

4.1. Operational definition

Let E be the frozen archive and R_q a claim-specific *admission rule* that fixes the document version, observation time, unit, service granularity, and evidence role. Let $E_q = R_q(E)$ contain only typed constraints legitimately bearing on claim q. Then $\mathcal{I}(E_q)$ denotes interpretations satisfying those constraints without silently supplying weights, allocations, or deployment records. We define identification only when the interpretation set is *nonempty*:

$$\text{Identified}(q; E_q) \iff \mathcal{I}(E_q) \neq \varnothing \ \wedge \ \left|\{q(i) : i \in \mathcal{I}(E_q)\}\right| = 1.$$

A contradictory same-scope constraint set with $\mathcal{I}(E_q) = \varnothing$ is flagged SOURCE CONFLICT, *never* identified by vacuous universal quantification. If the set is nonempty but contains two interpretations with $q(i_1) \neq q(i_2)$, the claim is NOT IDENTIFIED; the pair is an explicit witness. A uniquely constant value yields IDENTIFIED FOR THE SPECIFIED CLAIM, not general business truth. A planning-only record with no required outcome observations receives OUTCOME EVIDENCE ABSENT rather than a negative performance label.

This four-way disposition is a documentary audit convention, not a new statistical identification theorem. For the apparent "49 versus 51" discrepancy, the helper count

and direct detail-row enumeration are first recorded as discordant source statements. The narrower claim "the specified Draft-3 worksheet contains 51 detailed capability rows" is evaluated with an explicit row-enumeration rule. The executable example separately accepts *joint same-scope source assertions* or *alternative admissible interpretations*, rather than using an untyped list for both. Different versions or units are not silently imposed as joint constraints. Absence of implementation evidence never establishes service failure.

4.2. Layer 0: source/version identity

We verify the 25-entry parent archive, identify all nine analysis sources and one unique contextual reflection by bytes, document omissions/duplicate copies, separate Draft-2 from Draft-3, and do not treat successive planning versions as longitudinal performance. Within Draft-3 we compare helper/dashboard claims to direct enumeration of the detailed rows and mapping cells. We do not treat presentations of a proposed plan as final management authorization.

4.3. Layer 1: capability traceability and aggregation semantics

Let $C = \{c_1, \ldots, c_{51}\}$ denote detailed capabilities and $P = \{p_1, \ldots, p_{25}\}$ the final packages. The authored mapping $M \subseteq C \times P$ must satisfy

$$\forall c \in C: \quad \sum_{p \in P} \mathbf{1}\{(c,p) \in M\} = 1.$$

Each capability carries one source-authored status from

$$D = \{\text{Gap/Opportunity, Provided, Provided/Expandable, Provided/Opportunity}\}.$$

We preserve component statuses rather than infer component truth from an aggregate package label. A strict illustrative predicate,

$$g_{\text{strict}}(p) = \mathbf{1}\{\text{all mapped statuses are Provided or Provided/Expandable}\},$$

is used only to test whether the aggregate label retains enough information to recover this exact component property.

4.4. Layer 2: prioritization-rule identifiability

Draft-3 scores five focus areas on five ordinal criteria: strategic fit, market demand, network operations center (NOC) readiness, security operations center (SOC) readiness, and financial attractiveness. No criterion weights or aggregation rule are documented. Equal weighting is therefore a diagnostic, not the company's stated method.

For a weighted-sum diagnostic, let $w_k \geq 0$ and $\sum_k w_k = 1$. If the top-ranked focus area changes across weights in this explicitly *hypothetical* weighted-sum class, the numerical matrix cannot uniquely support the priority decision without a documented choice of rule. This witness does not assume the firm actually adopted weighted sums. This analysis does not challenge the narrative proposal that firewall services lead the Year-1 plan; final management authorization is separately unverified.

4.5. Layer 3: stage consistency

Let $L(p) \in \{1,2,3\}$ be a package's displayed launch year and $y(c)$ the detailed component year. Under the explicit all-components-at-launch convention,

$$T(p) = \max_{c:(c,p) \in M} y(c).$$

A direct component/package timing conflict is $T(p) > L(p)$. We separately flag later-named roadmap milestones because a later milestone can represent expansion or maturity rather than first availability.

4.6. Layer 4: financial identifiability

The final model gives family-year totals but no service-level tariff/allocation rule. To give the source the most favorable simple structure, we assume

$$Y_{fy} = \sum_{j \in S_{fy}} r_{jfy}, \qquad r_{jfy} \geq 0.$$

We then compare the number of service-year unknowns to the rank of the aggregation equations and construct distinct positive allocations that reproduce the same family totals. Rank deficiency is conditional on this stated service-year decomposition and does not identify the actual billing contract or avoidable cost.

4.7. Layer 5: evidence-to-readiness admission

Readiness is not inferred from planning status. Importantly, the company's own Draft-3 roadmap defines Year-1 exit criteria: at least three lighthouse clients, a working SLA process, approved monthly reporting, and a tested firewall risk-score model. The 90-day plan also requires catalogue/pricing/responsible–accountable–consulted–informed (RACI) approval, tooling/runbooks, team preparation, and lighthouse pilots before external launch. We therefore test whether the supplied archive contains evidence that these source-authored prerequisites were achieved.

Table 4. Claim-admissibility matrix. "Identified" means the admitted source is sufficient for the stated claim, not that the service is effective.

Claim	Minimum evidence	Case status
Capability-to-package membership	Exact names and mapping	Identified for source membership (51/51)
Final package launch label	Versioned catalogue year	Identified as planned label
Source-wide 49/51 total equivalence	Same-scope, reconciled total definition	Source conflict; 51 detailed rows enumerated
Numerical top priority from scorecard	Scores plus declared aggregation/weights	*not identified*
Full-scope package availability	Component scope plus authorized maturity/acceptance	*not identified*
Operational readiness	Executed runbook/tooling/pilot/SLA evidence	Outcome evidence absent
Service-level revenue/cost effect	Tariff or authorized allocation/contract rule	*not identified*
KPI achievement	Observed numerator/denominator and period	Outcome evidence absent

5. Results

5.1. Cross-format positive controls isolate the identified gaps

Before reporting discrepancies, we verify features that *do* reconcile across the final Draft-3 artifacts. The workbook, final report, and executive deck agree on the same five focus areas and their intended Year-1/2/3 sequencing. The consolidation workbook and paired package PDFs agree on 25 packages and the nominal 12/8/5 package-year split. After normalization, the report-selected financial convention matches the corresponding

excluded-market planning sheet, and the eight KPI target trajectories match between the workbook and final report.

These positive controls matter methodologically. The audit does not classify the source package as globally unreliable; it localizes where a stronger claim requires finer-grained evidence or an explicit decision rule. A separately implemented owner-side verification script additionally re-extracts selected mechanical results from the two original Draft-3 workbooks, independently of the de-identified derived-data ledger (Appendix D.4). This is a bounded source-to-result rerun, not full reproduction of every narrative or outcome claim.

5.2. The final mapping is complete, but source summaries disagree on its original service count

Direct enumeration of Draft-3 yields 51 detailed capabilities: 10 identity and access management/privileged access management (IAM/PAM), 10 governance, risk, and compliance (GRC), 10 data security posture management (DSPM)/privacy, 10 human-risk/artificial intelligence (AI), and 11 firewall capabilities. The final mapping assigns all 51 exact names once to 25 packages; three additional mapping phrases are explanatory elements rather than missing raw services.

Yet the workbook and both 25-service PDFs state that 49 services were consolidated into 25. The discrepancy is not confined to prose. The workbook's helper block hardcodes `Total Services = 49`; another helper formula is `COUNTIF(E14:E199,"*Provided*")`, which starts below the first two IAM detail rows. The total helper then points back to the hardcoded 49. Direct detailed-year enumeration is 24/17/10, whereas the helper block displays 21/18/10. These mechanics demonstrate a hard-coded total and a non-exhaustive status-helper range. They do not establish how the 49 figure entered the package PDFs or explain every year-count discrepancy.

The same-week Draft-2/Draft-3 evolution reinforces why source locking matters. Draft-2 uses a ten-area, five-market, Year-3-ARR decision object; Draft-3 uses five final focus areas, a four-market financial scope, 25 packages, and cumulative three-year revenue. Differences between the versions cannot be interpreted as observed growth.

5.3. Package aggregation loses component-status information

Detailed status counts are 30 Gap/Opportunity, 12 Provided, 8 Provided/Expandable, and 1 Provided/Opportunity (Figure 2). Twenty of 25 packages contain at least one Gap/Opportunity component; 11 consist entirely of such components; four satisfy $g_{\text{strict}} = 1$; only one consists entirely of exact Provided components.

Seven packages share the aggregate label Provided/Expandable, but their detailed component profiles differ. In the original consolidation mapping, de-identified S06 has the component-status vector (Provided, Gap/Opportunity, Provided/Expandable) and S07 has (Provided, Provided/Expandable); both bear the aggregate label Provided/Expandable. Consequently $g_{\text{strict}}(\text{S06}) = 0$ while $g_{\text{strict}}(\text{S07}) = 1$. A single-valued function of the aggregate label cannot recover this exact predicate for both packages. The underlying workbook join is checked in the restricted source verifier; Appendix B.2 and the de-identified evidence record both status vectors. This is a case-specific information-loss witness, not evidence that the authors intended the label to encode full component maturity.

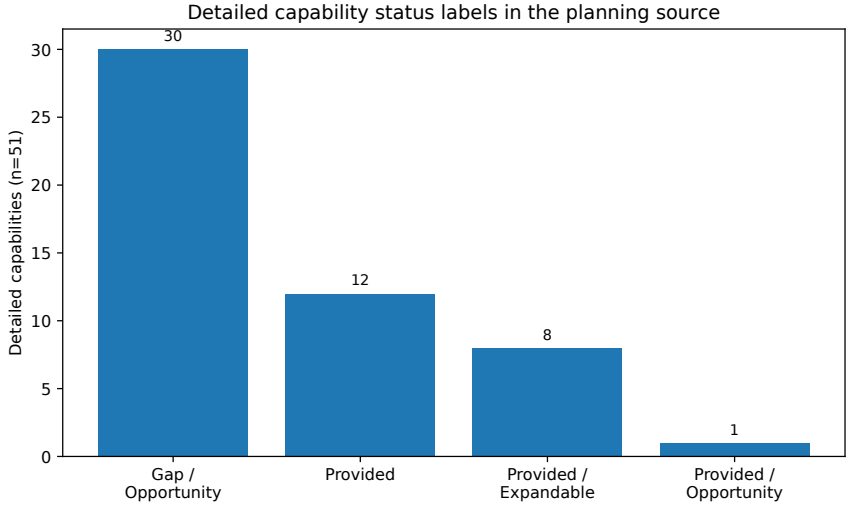


Figure 2. Source-authored detailed capability labels. Gap/Opportunity is a planning label, not an observed service failure.

5.4. The scorecard does not independently reproduce the top priority without a decision rule

The five score vectors are shown in Table 5. Equal weights give means of 4.6 (Firewall), 4.4 (IAM/PAM), 4.0 (DSPM), and 3.8 each (Human Risk and GRC). However, equal weighting is undocumented.

Table 5. Draft-3 focus-area score vectors and weight robustness. Criteria order is strategic fit, market demand, NOC readiness, SOC readiness, financial attractiveness.

Focus area	Score vector	Equal-weight mean	Relation to Firewall under arbitrary nonnegative normalized weights
Managed Firewall Services	(5,4,5,4,5)	4.6	Reference
Managed IAM & PAM	(5,4,4,4,5)	4.4	Firewall weakly dominates
Managed GRC	(4,3,4,3,5)	3.8	Firewall weakly dominates
DSPM / Data Privacy	(4,4,3,5,4)	4.0	Weight-sensitive
Human Risk / AI Awareness	(3,5,3,4,4)	3.8	Weight-sensitive

For DSPM,

$$\text{Firewall} \geq \text{DSPM} \iff w_{\text{strategic}} + 2w_{\text{NOC}} + w_{\text{financial}} \geq w_{\text{SOC}}.$$

For Human Risk,

$$\text{Firewall} \geq \text{Human} \iff 2w_{\text{strategic}} + 2w_{\text{NOC}} + w_{\text{financial}} \geq w_{\text{demand}}.$$

Putting all weight on SOC readiness makes DSPM score 5 versus Firewall 4; putting all weight on market demand makes Human Risk 5 versus Firewall 4. Thus the numeric scorecard alone does not identify a unique top alternative. This is established MCDA sensitivity [10]. The final narrative nevertheless explicitly selects Firewall as the Year-1 flagship based on delivery fit and NOC readiness; our result is therefore a reproducibility boundary for the *scorecard*, not a claim that the management choice is invalid.

5.5. One direct stage conflict and five broader maturity signals

The detailed capability years are 24/17/10 for Years 1/2/3, while package labels are 12/8/5. Exactly one mapped capability is later than its package: Control Effective-

ness Monitoring is Year 2 inside a combined Year-1 GRC package. Under the strict all-components-at-launch convention, only this package moves, producing 11/9/5 (Figure 3; Appendix B.4).

The roadmap also names advanced scope later for five packages (S08, S21, S22, S24, S25), including NGWAF, SASE/lifecycle, OT/ICS, OT/IoT SOC, and microsegmentation. A broader sensitivity that treats each later-named milestone as first full-scope eligibility gives 7/11/7. That is not an approved schedule. Both an early limited-scope launch and a later full-scope maturity interpretation remain compatible with the source unless the service tier and acceptance scope are explicitly versioned.

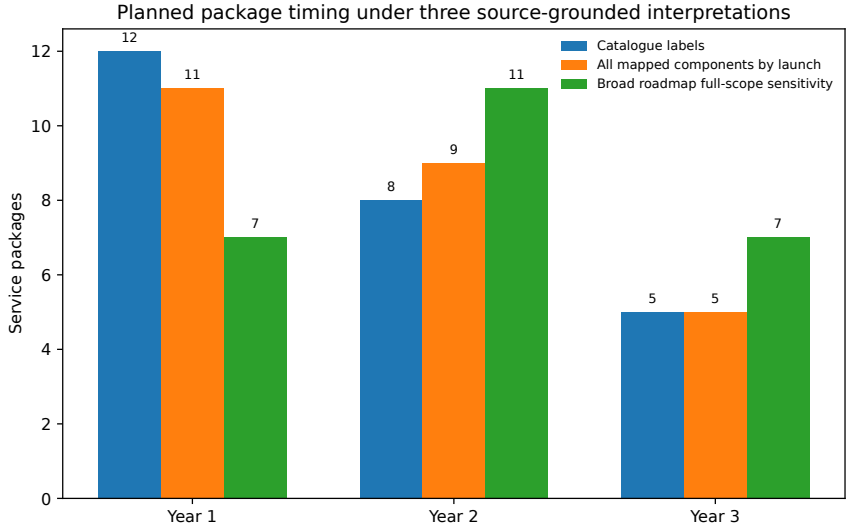


Figure 3. Nominal package years and two explicit sensitivities. Neither sensitivity is an observed deployment schedule.

5.6. Service-level financial effects are structurally underidentified

The final scenario reports a normalized three-year revenue index of 1.000 across five service families. The amount itself is scenario-conditioned: because no country-level revenue split exists, the workbook applies an editable 12% allocation for an excluded market, i.e., a 0.88 market factor.

No source record allocates family totals to the 25 packages or individual components. Under the favorable additive decomposition, Year 1 has 12 service-level unknowns and three independent family totals, Year 2 has 20 versus four, and Year 3 has 25 versus five. Across annual decompositions there are 57 unknowns but only 12 independent equations, leaving 45 free dimensions (Figure 4).

For any positive family-year total Y with $k \geq 2$ services, both the equal split Y/k and a distinct positive allocation assigning $2Y/3$ to one service and $Y/[3(k-1)]$ to each other service reproduce the same aggregate. For example, in a separate normalized two-service illustration, $(0.5, 0.5)$ and $(0.75, 0.25)$ both sum to one. These are algebraic witnesses, not company service revenues. With one disjoint equation for each of the 12 positive family-year groups, the block-incidence matrix has rank 12; its 57 columns therefore leave a 45-dimensional nullspace. The assumptions and normalized witness are detailed in Appendix C.2. A package's revenue share is not identified, and a delay effect would additionally require marginal costs, customer retention and contract timing.

The workbook also encodes two post-resource conventions. Normalized by planned three-year revenue, the report-selected convention yields 0.3274 after resources, whereas the workbook's service-row convention yields 0.4109; the difference is 0.0835 of planned

revenue. The discrepancy requires an owner-approved accounting definition; neither quantity is realized profit. A dashboard cell additionally contains `COUNTA(#REF!)`.

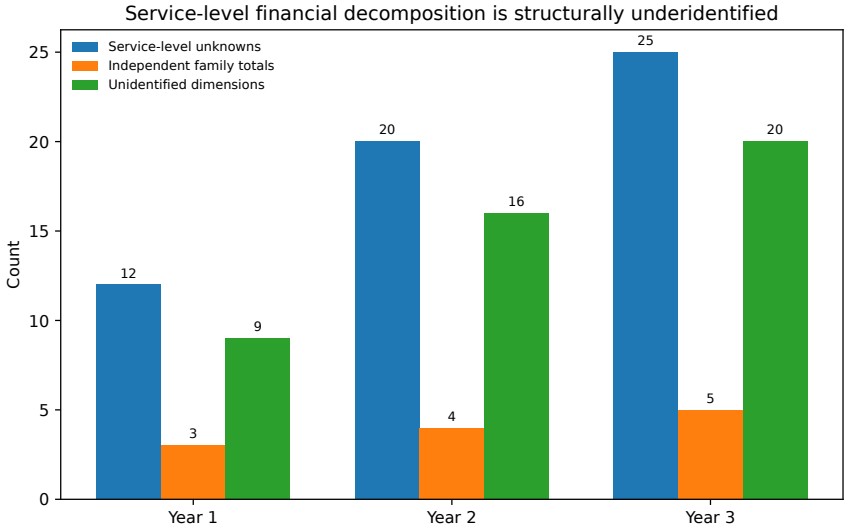


Figure 4. Service-level financial decomposition is structurally underidentified even under a simple additive model favorable to identification.

5.7. The source defines launch prerequisites but does not document their closure

The plan itself warns against over-promising before delivery capability, tools, and NOC/SOC handoff are mature. Its Year-1 exit criteria require at least three lighthouse clients, a working SLA process, approved monthly reporting, and a tested firewall risk-score model. The 90-day plan calls for catalogue/pricing/RACI approval, runbooks/tooling, team preparation, and lighthouse pilots before external launch.

The supplied archive documents these as planned actions and targets (Appendix C.4). A separately hash-checked final-week reflection says the refined plan was presented to management for approval; no later approval minute is supplied. The archive does not contain a dated closure of the exit criteria, signed service-release acceptance, observed KPI numerators/denominators, or realized service-level revenue. Accordingly, the documentary disposition for achieved operational release is OUTCOME EVIDENCE ABSENT; the number of packages actually released is unknown, rather than established as zero.

6. Discussion

6.1. A roadmap can be coherent yet not decision-identifiable at the requested granularity

The case does not show that the roadmap is wrong. It shows that different claims require different evidence granularity. Capability membership and final package labels are identified. Full-scope availability, the numerical scorecard's top alternative and service-level economics are not identified without additional rules; achieved operational readiness and KPI performance lack the required outcome observations in this archive.

The important distinction is between *portfolio coherence* and *claim identifiability*. The final mapping is complete, the planning narrative explicitly prefers Firewall, and the roadmap anticipates staged maturity; the supplied documents do not certify final management approval. Yet the same evidence does not uniquely answer every service-level counterfactual later asked of it.

6.2. Why this audit should precede optimization

An optimizer can only be as meaningful as its parameters and decision rules. Assigning arbitrary service revenue shares would manufacture financial precision; assigning

undocumented criterion weights would manufacture a scorecard ranking; treating later roadmap milestones as hard launch prohibitions would manufacture stage constraints; and interpreting missing acceptance records as failed delivery would manufacture an operational outcome.

To implement the claim gate, each audit record declares (i) the requested claim and unit, (ii) source version/time/provenance, (iii) the constraints actually supported by each admitted artifact, (iv) a separately labelled assumption class if one is examined, (v) either a constant-answer certificate, a contradictory same-scope source pair, an alternative-interpretation witness, or a missing-outcome-evidence reason, and (vi) a minimal new-evidence request. The accompanying machine-readable casebook and tests demonstrate these outputs; they do not automate semantic judgment or make the protocol externally validated.

The proposed audit sequence is therefore:

1. lock source versions and decision universe;
2. prove capability/package traceability;
3. preserve component semantics when testing aggregate claims;
4. make the prioritization rule explicit and test weight sensitivity;
5. distinguish nominal launch, minimum viable scope, and full-scope maturity;
6. test whether financial aggregates identify the requested service-level counterfactual;
7. require observed release/assessment evidence before promoting planning states to operational readiness.

This complements portfolio optimization, MCDA, repository integration, assurance cases, partial identification, OSCAL, and security measurement; it does not replace them. Compared with the six-company evidence-management interview study, this paper offers narrower executable, within-case decision witnesses rather than cross-organization findings. Compared with assurance-case defeater discovery, it checks algebraic uniqueness and admissible planning scope rather than constructing an assurance argument about system safety or security [18,19]. These case-specific witnesses are logically informative, but they do not constitute a randomized comparison of audit approaches. Each decision test has a concrete witness or missing-evidence disposition, not a numerical "quality score".

6.3. Systems research comparators and the system boundary

Recent systems-oriented studies offer particularly informative comparisons. Kocaoglu's purchasing-process roadmapping artifact uses differentiated capability profiles and explicit prioritization to link assessment to planned intervention, supported by expert development and multiple pilot applications [28]. The present study does not introduce or externally validate a competing maturity instrument; it checks whether *pre-existing* MSSP package and score records identify the decision at the requested granularity. Plevnik's security-sensitive information-systems service-governance case includes interviews and longitudinal incident data [29], providing operational evidence that our *planning-only* archive lacks. Fowler et al.'s model-based cyber evaluation toolkit links system threats, proposed controls, and management decisions and includes practitioner face-validity evidence [30]; our test concerns source-to-portfolio decision admissibility, not threat-control effectiveness or expert-rated tool utility. Chen et al. distinguish digital traceability from verified evidence and physical compliance in a normative battery-identity governance model [31]; our narrower counterpart is a deterministic documentary witness that traceable package and financial records can still leave a specified decision non-unique. Thus neither traceability insufficiency nor decision transparency is claimed as a new general principle.

The systems-level contribution here is a bounded account of how *information loss, missing decision rules, inconsistent planning scopes, and absent outcome records* propagate across

interdependent stages of one service-portfolio planning system. The claim gate locates the missing evidentiary link and identifies the minimal additional evidence needed before the next managerial inference. It is not a tested intervention, an operational assurance certification, a demonstrated productivity gain, or a multi-organization validation of a systems theory.

6.4. Case-based contrast with an inventory-only check

The case permits a narrow, reproducible ablation of *questions*, not a comparison of auditor accuracy. A minimal document-presence check asks only whether a relevant record or label is present; it does not claim to establish sufficiency. Table 6 shows what the claim-typed protocol additionally resolves when the intended question is made explicit. The examples and comparator were defined from the fixed source set, and no independent expert ground truth, time saving or false-reassurance rate is claimed. Assurance cases and OSCAL already handle claims and supporting evidence; this contrast does not demonstrate superiority over those richer methods [17,21,22].

Table 6. Document presence versus an identified decision claim: source-grounded examples, not an auditor-performance benchmark.

Question	Document-presence observation	Additional claim-gate finding
51 detailed capabilities?	Row catalogue and 49 helper both present	Source conflict for an undifferentiated total; 51 identified for typed detailed-row enumeration
Component-wise predicate from package label?	Provided/Expandable appears on S06 and S07	Not identified from label: opposite strict predicates
Scorecard's unique top focus?	Five score vectors present	Not identified absent rule; three alternative weight vectors give different winners
Individual package revenue?	Family-year totals present	Not identified: 57 unknowns, rank 12 under stated additive model
Actual Year-1 release?	Launch plan and exit criteria present	Outcome evidence absent; neither operational success nor failure established

6.5. Minimum additional evidence for decision use

A negative identification result is actionable only if the next admissible evidence is specified. Table 7 identifies the smallest *type* of additional record needed to revisit each claim; the records would still need version, scope, date and authorization checks before a conclusion is promoted.

Table 7. From non-identified claims to minimum required evidence. This is a due-diligence request register, not proof those records exist.

Held decision	Additional owner-approved record / rule	What it could identify
Numerical priority	Criteria meaning, aggregation rule, admissible weights, tie policy and signed decision record	Reproducible numeric ordering, distinguished from narrative choice
Package full-scope launch	Component and service-tier definitions, time-stamped release and acceptance gates	Specific scope ready at a specified date, not quality in all settings
Package delay economics	Per-package commercial allocation/tariff, customer/contract horizon, avoidable-versus-shared cost and displacement rule	Defined scenario effect on contribution, conditional on assumptions
KPI achievement	Period-level observed counts, denominators, scope, collection rule and QA record	Realized KPI for the reported period, not causal impact
Executive authorization	Signed approval/decision minutes and versioned launch-governance disposition	Approval of the named plan, not completed implementation

6.6. Implications for MSSP governance

Three governance implications follow. First, a commercial package label should not substitute for component evidence when the decision is component-sensitive. Second, scorecards should publish the aggregation rule and weight rationale if the numeric ranking is intended to justify a priority decision. Third, the financial model should preserve a documented bridge from family forecast to package price, customer denominator, shared staffing, and avoidable cost if package-level delay economics are to be claimed.

The case's NOC/SOC role matrix reinforces the point: responsibility, specialist accountability, service delivery, and customer approval can sit with different actors. A service can therefore be commercially defined before all evidence needed for operational acceptance exists.

7. Limitations and Claim Boundaries

This is a single prospective industrial planning case, not a statistical sample of MSSPs. There is no second-company replication or independent blind coding. A finite source-level witness supports the stated counterexample, not claims of improved audit accuracy or external predictive validity. The 25 archive entries include duplicates, alternative document representations and non-analytical context; they are not 25 independent observations. The 51 detailed capabilities likewise are not independent field replications. It does not observe deployments, customer outcomes, realized revenue, SLA performance, or incident effectiveness. The source-authored status vocabulary is not a universal maturity scale.

The weighted-sum scorecard analysis is diagnostic because the source does not specify that weighted summation was its intended aggregation rule. Its purpose is to prove that the raw score matrix alone is insufficient to reproduce a unique top choice, not to recommend alternative weights. The 11/9/5 and 7/11/7 stage schedules are sensitivities, not recommended launch plans. The additive financial decomposition is intentionally favorable to identification and is not claimed to describe billing practice. The 12% excluded-market adjustment is an explicit planning assumption necessitated by missing country-level revenue splits.

The literature-lineage comparisons are conceptual and source-test linked, not direct replications or empirical head-to-head evaluations of existing portfolio, repository, or security-assurance approaches. In particular, any improvement over a trained auditor, an OSCAL implementation, or a full assurance-case review remains untested. The study confines capability-to-package matching to a source-integrity control, not an evaluation of managed-service obligations, role-level assurance, or security-control compliance; those require a distinct unit of analysis and should not be confused with these decision-identifiability results. Only the limited, de-identified derived-data and executable-code capsule specified in the Data Availability Statement has been released publicly; access to original organizational records remains restricted and requires separate data-owner permission. For this named-author manuscript, the industrial case remains de-identified and financial quantities are normalized; this does not imply double-blind peer review. The protocol has not yet been replicated on a second MSSP portfolio, so cross-company transferability remains a methodological proposition rather than an empirical estimate.

8. Conclusion

A cybersecurity service roadmap can be internally traceable while failing to identify every decision later asked of it. In this 25-service MSSP case, all 51 detailed capabilities map exactly once to the final packages, but a hard-coded 49-service summary conflicts with their enumeration, package labels compress component semantics, the numerical scorecard lacks a decision rule that uniquely determines the top alternative, one direct component/package

timing conflict and several later maturity signals create scope ambiguity, and family-level finance cannot identify service-level economics. The source also specifies launch prerequisites without supplying evidence of their closure.

The practical lesson is evidence-before-optimization. Before ranking, scheduling, or valuing individual services, organizations should establish that the source record identifies the decision at the same granularity. Claim identifiability provides a reproducible way to distinguish a coherent planning portfolio from decision-ready service evidence without converting missing information into false precision or inferred failure.

Author Contributions: Author confirmation required before submission. The project-specific CRediT roles for M.E. and G.M. have not yet been confirmed by the individual authors. Authorship order does not establish the division of conceptualization, analysis, validation, manuscript preparation, or supervision.

Funding: Author confirmation required before submission. The presence or absence of research funding, grant support, institutional sponsorship, or article-processing-charge support has not been verified for this manuscript. No funding or no-funding declaration is inferred.

Institutional Review Board Statement: Not applicable. The study audits archival planning documents and reports no research intervention involving human or animal participants.

Informed Consent Statement: Not applicable. No study participants were recruited.

Data Availability Statement: A public source-free reproducibility capsule containing de-identified derived inputs, a claim-decision casebook, deterministic arithmetic and logic checks, software regression tests, and the author-review PDF is available at https://github.com/shaikhamalkawi-ux/mssp-decision-evidence-audit. The fixed code snapshot is identified by GitHub commit `bf29b48d79`. The capsule reproduces the specified derived witnesses and algorithmic semantics, but not the full raw-company-workbook-to-manuscript pipeline or independent operational validation. Original company spreadsheets, reports, absolute financial records, exact source-path ledgers, and owner-controlled original-source replay code remain confidential and are not distributed. Requests for restricted source access require separate approval of the data owner and cannot be guaranteed. A previously executed owner-side checker reproduced 72 selected source-linked assertions, but those original records and checker are not in the public capsule. See Appendices A–D for the evidence and scope boundaries. Public visibility does not establish a license to redistribute the underlying corporate materials.

Acknowledgments: OpenAI ChatGPT (GPT-6) assisted with English-language editing, literature discovery support, LaTeX preparation, code scaffolding, and consistency-check workflows during manuscript preparation. Such assistance does not constitute independent domain-expert validation, a new empirical experiment, or authorship. The human authors retain responsibility for verifying the source evidence, citations, calculations, code, and publication statements. The wording of this disclosure is subject to both authors' final review.

Conflicts of Interest: Author confirmation required before submission. Project-specific financial, employment, organizational, and other potentially competing interests have not yet been declared by both authors. A positive declaration or a verified no-conflict statement must replace this notice before submission.

Appendix A. Source archive and version reconciliation

Appendix A.1. Source selection and analytical identity

The parent archive was fixed by SHA-256 before analysis. All nine analytical source files matched the internal source manifest byte-for-byte. The register uses de-identified source IDs; full source names remain in the confidential audit ledger.

Table A1. De-identified source register and analytical roles.

ID	Artifact type	SHA-256 prefix	Role / principal audit finding
S1	Earlier planning workbook	4baf84570a33	Earlier 10-area planning universe, five-market scope, Year-3 ARR scenario; internal roadmap/dashboard staging differences.
S2	Earlier executive deck	8b389fb63029	Version context, ten new areas, pilot logic and immediate actions.
S3	Earlier strategy roadmap	0ec1fe47ce83	Earlier customer targets, revenue ranges, dependencies and explicit scenario caveats.
S4	Final planning workbook	5efdcb233ffe	Primary quantitative source: 51 capabilities, five focus score vectors, years/statuses, KPI targets, financial/resource formulas and helper logic.
S5	Final executive deck	6aa9b25b568a	Final five-focus portfolio, firewall-led launch, exit criteria and 90-day launch actions.
S6	Final report	7cfdc29145a9	Final roadmap/financial narrative, strategic overpromising risk, selected post-resource convention and launch prerequisites.
S7	Consolidated catalogue PDF	37cfc76d6bbd	25 packages, 12/8/5 planned years, aggregate statuses and stale 49-to-25 narrative.
S8	Mapping PDF	3e3b7fde7d79	Mapping display; stale 49 narrative despite 51 exact raw names in mapped strings.
S9	Consolidation workbook	1c41612214d7	Machine-readable 25 packages and mappings; 51/51 raw names once each plus three explanatory phrases.
S10	Final-week reflection PDF	654d5f457b	Context-only: plan presented to management for approval; not evidence of executive acceptance or service launch.

Entry-level admission.

The immutable parent archive contains 25 entries: 23 material entries and two exporter-error texts. Two pairs of material entries are byte-identical weekly-reflection copies, leaving 21 distinct material payloads. Nine distinct analytical spreadsheet/PDF sources (S1–S9) enter the numerical and cross-format tests; one distinct final-week reflection (S10) enters *only* the approval-status contextual check. Eleven other distinct material payloads were excluded from the numerical analysis as alternate editable representations, weekly context/presentation material, or presentation photographs. These are not extra independent case observations. The restricted entry-level ledger records each of the 25 original paths, its SHA-256, its disposition, and duplicate-of links; no unselected source was silently treated as contradictory numerical evidence.

Approval-status boundary (S10).

The final-week reflection (byte-identity SHA-256 prefix `654d5f457b`) states that the refined plan was presented to management for approval. A duplicate copy of the same PDF is present in the archive. This supports a proposal/submission-to-management claim, not proof of final approval or actual first-year release. No approval minute or later implementation closure was admitted in the archive.

Appendix A.2. Differences between planning versions

The two versions differ in decision universe, market scope, and financial metric.

Table A2. Differences between the earlier and final planning versions.

Dimension	Earlier version	Final version
Portfolio object	10 new areas plus references to identity and firewall work	5 final focus areas; 51 detailed capabilities consolidated to 25 packages
Financial scope	Five-market scope	Four-market financial scope
Headline quantity	Year-3 ARR scenarios	Cumulative three-year planning revenue
Roadmap use	Foundation/scale/lead planning	Final five-focus staged implementation
Interpretation	Earlier planning version	Final planning version; not a realized outcome

The earlier version also contains internal staging differences: Human Risk/AI appears in different years across its dashboard/catalogue and roadmap, and one Year-1 dashboard priority is omitted from the roadmap's Year-1 key-service cell. These are differences between planning versions, not observed delivery failures.

Appendix A.3. Cross-format reconciliation controls

Four final-plan features reconcile across the source representations: (1) the same five focus areas and staged Year-1/2/3 logic appear in the workbook, final report, and executive deck; (2) the consolidation workbook and the paired catalogue PDFs agree on 25 packages and the nominal 12/8/5 split; (3) the report-selected financial totals agree with the final excluded-market planning sheet under the selected convention; and (4) the eight KPI trajectories match between workbook and final report. These controls show that the audit isolates claim-specific boundary problems rather than treating every source difference as an error.

Appendix A.4. The 49-versus-51 source discrepancy

Direct enumeration of the final workbook yields 51 capability rows with year counts 24/17/10. The helper block instead displays 49 total services and 21/18/10.

Relevant workbook mechanics:

- the total-services helper is hardcoded at 49;
- a status helper uses `COUNTIF(E14:E199,"*Provided*")`, starting below the first two identity-service detail rows, both labelled Provided;
- the displayed total helper points back to the hardcoded 49;
- the 21/18/10 year helper values are not linked to the complete detailed-year enumeration.

These checks establish a non-exhaustive status-helper range and a hard-coded summary of 49. The range omission excludes two Provided-containing rows, but it does not establish the historical origin of the 49 summary, demonstrate an automatic link to the package PDFs, or explain every year-count difference.

Appendix B. Capability aggregation, priorities, and stages

Appendix B.1. Mapping and component-status composition

The 25-package mapping contains 54 semicolon-delimited phrases: 51 exact matches to all 51 detailed capability names, each once, plus three explanatory phrases.

Detailed status counts are 30 Gap/Opportunity, 12 Provided, 8 Provided/Expandable, and 1 Provided/Opportunity. Across packages, 20/25 contain at least one Gap/Opportunity component; 11/25 contain only Gap/Opportunity components; 4/25 have every component in {Provided,

Provided/Expandable}; and 1/25 has every component exactly Provided. These are documentary compositions, not measured maturity.

Appendix B.2. Package-label information-loss witness

Using the exact source-name join from the final detailed capabilities (source S4) to the consolidation mapping (source S9, mapping rows 10–11), two packages share the aggregate label Provided/Expandable:

Table B1. Component-status witness for equal aggregate package labels.

Package ID	Source-authored detailed component statuses	g_{strict}
S06	Provided; Gap/Opportunity; Provided/Expandable	0
S07	Provided; Provided/Expandable	1

No component status was inferred from the aggregate package label. The original source-join script is supplied only in the author-controlled archive; the de-identified vectors and deterministic derived check are in `evidence/package_label_witness_v8.json` and `code/check_casebook_v8.py`. This establishes information loss for the declared strict predicate, not actual operational performance.

Appendix B.3. Prioritization sensitivity

The final workbook supplies five score vectors on criteria ordered as strategic fit, market demand, NOC readiness, SOC readiness and financial attractiveness:

$$\begin{aligned} \text{IAM/PAM} &= (5,4,4,4,5),\\ \text{DSPM} &= (4,4,3,5,4),\\ \text{Human Risk} &= (3,5,3,4,4),\\ \text{GRC} &= (4,3,4,3,5),\\ \text{Firewall} &= (5,4,5,4,5). \end{aligned}$$

No criterion weights or aggregation rule are supplied. Equal-weight means are 4.4, 4.0, 3.8, 3.8 and 4.6 respectively. Firewall weakly dominates IAM/PAM and GRC, but not DSPM or Human Risk.

For nonnegative weights normalized to sum to one:

$$\text{Firewall} \geq \text{DSPM} \iff w_S + 2w_N + w_F \geq w_{SOC},$$

$$\text{Firewall} \geq \text{Human} \iff 2w_S + 2w_N + w_F \geq w_D.$$

All weight on SOC readiness makes DSPM 5 versus Firewall 4; all weight on market demand makes Human Risk 5 versus Firewall 4. The score matrix alone therefore does not reproduce a unique top focus area. The final narrative separately identifies Firewall as the Year-1 flagship.

Appendix B.4. Stage-consistency diagnostics

Detailed component-year counts are 24/17/10; final package years are 12/8/5. One direct component/package conflict is present. The mechanical all-components-at-launch convention yields 11/9/5.

Five packages contain later-named roadmap milestones. A broader "later milestone = first full-scope eligibility" sensitivity yields 7/11/7. This is not an approved schedule and may overstate the meaning of later maturity/expansion entries.

Appendix C. Financial identification and release prerequisites

Appendix C.1. Financial equation counts and normalized reconciliation

Table C1. Conditional degrees of freedom in the additive family-year decomposition.

Year	Service-year unknowns	Family totals	Rank	Free dimensions
1	12	3	3	9
2	20	4	4	16
3	25	5	5	20
Total annual decompositions	57	12	12	45

Normalize planned three-year revenue to 1.000. Annual shares are 0.1081, 0.2966 and 0.5953. The final model applies a 0.88 market factor because an excluded market is represented by an editable 12% allocation in the absence of country-level revenue splits.

Gross margin before resources is 0.4930 of planned revenue and modeled resource cost is 0.1655. The report-selected post-resource convention yields 0.3274; the workbook's alternative service-row convention yields 0.4109. The difference is 0.0835 of planned revenue. Neither quantity is a realized profit observation.

Appendix C.2. Rank deficiency and non-unique allocation witness

Under the declared additive model, let $n_{fy} \geq 1$ count the service-year entries inside active family f in year y. Stack the 57 unknown nonnegative entries into $\mathbf{r}$; the 12 source family-year totals are $\mathbf{Y} = A\mathbf{r}$ where A has one disjoint indicator row per family-year group. Its rows have non-overlapping nonempty supports and are therefore linearly independent, so

$$\operatorname{rank}(A) = 12, \quad \dim \ker(A) = 57 - 12 = 45.$$

The rank statement assumes these are the only independent equations and there are no additional observed service tariffs, contractual restrictions or package allocation records. The nonnegative feasible set is not automatically a linear space; "45 free dimensions" refers to the rank-nullity structure and, for strictly positive allocations and positive totals, its local feasible dimension.

For a normalized, two-service illustrative family-year block, the positive vectors

$$\mathbf{r}^{(1)} = (0.50, 0.50), \qquad \mathbf{r}^{(2)} = (0.75, 0.25)$$

both produce $Y = 1$ but disagree about the revenue of the first service. If an actual family-year contains more services, hold their positive allocations fixed and transfer a small amount between any two positive entries; the same equation still holds. These numbers are *algebraic illustrations*, not disclosed or reconstructed company revenue. A service delay's net cash consequence remains a distinct, stronger estimand requiring customer, tariff, substitution, avoidable-cost and time assumptions. Details and checks are provided in the executable casebook.

Appendix C.3. Claim-decision record and inventory-only contrast

The locked, de-identified casebook `evidence/claim_decision_casebook_v8.json` contains machine-readable claim/unit, admission, status, witness and missing-record fields. A document-inventory check can establish that a label, vector, total or plan is present; it cannot, *by itself*, answer every stronger claim. The fixed five-row contrast in Table 6 is a logical scope contrast, not a measured superiority, benchmark precision, time saving or independent-validation result. The companion script checks typed evidence, the package counterexample, three scorecard alternatives, and the normalized financial witness. No proprietary original sheet enters the de-identified package.

Appendix C.4. Source-defined release evidence requirements

The final roadmap's Year-1 exit criteria are:

1. at least three lighthouse clients;
2. SLA process working;

3. monthly reporting approved;
4. firewall risk-score model tested.

The 90-day plan additionally requires catalogue/service-tier/RACI/pilot-scope approval, runbooks and integration work, training, and lighthouse pilots before external launch. The supplied planning archive contains these requirements but no recorded closure decision for them.

Appendix D. Additional audit observations and verification limits

Appendix D.1. Additional source-document observations

Preserved for audit completeness but not used as central claims:

- one executive-dashboard cell contains `COUNTA(#REF!)`;
- dashboard client counts point to a legacy financial sheet while revenue/margin text points to the updated-scope sheet; numeric client totals coincide in the inspected version;
- the final report contains a one-day cover/prepared-date discrepancy;
- one report sentence labels an adjusted-revenue value as a reverse-calculated serviceable-market estimate, while the workbook computes it as adjusted revenue; no alternative market-size conclusion is drawn.

Appendix D.2. Claim states and conflict handling

The audit uses a typed claim-admission rule before checking uniqueness. Formally, $\mathcal{I}(E_q) = \varnothing$ implies *source conflict*, not vacuous identification. For example, the source helper states 49 while direct row enumeration counts 51 under the detailed-row unit: these are reported as discordant claims before taking the direct enumeration as the evidence for the narrower row-count statement. A nonempty set that admits different weighted-sum winners or positive financial allocations yields a claim classified as *not identified*. In contrast, recorded nominal package years and exact mapping are *identified as source facts*, while missing SLA or launch-acceptance records are classified as *outcome evidence absent*. These four dispositions are mutually distinct for each typed claim, and the presence of a plan cannot be counted as an observation of implementation.

The executable derived-data examples are contained in `code/claim_gate_demo.py`, `code/verify_anonymized.py`, and the independent casebook check `code/check_casebook_v8.py`. This is a derived-data audit, not a distribution of original corporate sheets.

A separate, source-free regression suite checks 26 deterministic software properties of the typed claim gate, including rejection of cross-version, cross-unit and cross-definition assertions, explicit handling of empty interpretation sets, missing component statuses, tied scores and distinct positive allocations with the same total. These tests verify the declared program semantics on already specified examples. They do not constitute independent validation on 26 companies, new source-data tests or a complete raw-workbook-to-manuscript replay.

Appendix D.3. Boundaries of the findings

The study does not treat presentation for approval as final executive authorization and does not assert that any package failed, that all packages operated, that Firewall should be replaced as the strategic priority, that equal weights are the intended scorecard method, that either timing sensitivity is a recommended schedule, or that either post-resource quantity is realized profit. The contribution is the boundary between claims supported by the planning record and claims requiring a decision rule or observed operational evidence.

Appendix D.4. Bounded original-workbook source-to-result rerun

An owner-side checker was implemented separately from the earlier anonymized-derived-data tests and run directly against the immutable original archive. It imports the two relevant Draft-3 XLSX payloads using a spreadsheet parser, joins the raw detailed capability names to the source-authored package mapping, recomputes the declared component-stage predicate and focus-score arithmetic,

and recomputes the relevant normalized family-year financial identities. No original corporate workbook is included in the de-identified package.

Table D1. Scope and outcome of the selected original-source verification.

Original-source gate	Recomputed outcome / scope
Source and membership	Parent archive identity and 25-entry composition; two Draft-3 workbook checksums; 51 unique capability names, 51 exact one-to-one links, 25 packages, three non-matching explanatory strings.
Stage and labels	Detail-year 24/17/10, package-year 12/8/5, one later component, and the 11/9/5 all-components sensitivity; opposite strict predicates for source-anonymized S06/S07 under an equal aggregate label.
Scorecard	Five source score vectors recomputed; equal, SOC-only and demand-only illustrative weights have three different leaders. No weights are represented as the company's adopted rule.
Finance	Annual family revenue and gross-margin arithmetic, modeled resource-cost reconciliation, both post-resource conventions, 57 active package-year unknowns versus 12 positive family-year aggregates, and the conditional 45-dimensional linear nullspace. Only normalized ratios are released.
Not included in this gate	The 7/11/7 broad full-scope interpretation, semantic review of every PDF passage, global absence of operational records, causal claims, expert validation or cross-company replication.

The author-controlled runner passed 72 mechanically specified checks, including individual revenue, gross-margin and resource-row recomputations; these are not 72 statistically independent case observations. This strengthens reproducibility of the selected mechanical findings, not the paper's external validity. The exact original archive remains restricted. Reproduction at other institutions depends on legitimate authorized access to the source files, which cannot be replaced by the public derived-data package.

References

1. T. Kohlborn, E. Fielt, A. Korthaus, and M. Rosemann, "Towards a Service Portfolio Management Framework," *ACIS 2009 Proceedings*, Paper 21, 2009.
2. M. Comerio et al., "Service portfolio management: A repository-based framework," *Journal of Systems and Software*, vol. 104, pp. 112–125, 2015. doi:10.1016/j.jss.2015.01.055.
3. C. Batini and M. Comerio, "A Methodology for the Integration of Service Repositories," *Communications of the IBIMA*, vol. 2016, article 790219, 2016. doi:10.5171/2016.790219.
4. F.-R. Lin and P.-S. Hsieh, "A SAT View on New Service Development," *Service Science*, vol. 3, no. 2, pp. 141–157, 2011. doi:10.1287/serv.3.2.141.
5. L. J. Menor and A. V. Roth, "New Service Development Competence and Performance: An Empirical Investigation in Retail Banking," *Production and Operations Management*, vol. 17, no. 3, pp. 267–284, 2008. doi:10.3401/poms.1080.0034.
6. J. Liesiö, P. Mild, and A. Salo, "Robust portfolio modeling with incomplete cost information and project interdependencies," *European Journal of Operational Research*, vol. 190, no. 3, pp. 679–695, 2008. doi:10.1016/j.ejor.2007.06.049.
7. M. Tavana, G. Khosrojerdi, H. Mina, and A. Rahman, "A hybrid mathematical programming model for optimal project portfolio selection using fuzzy inference system and analytic hierarchy process," *Evaluation and Program Planning*, vol. 77, 101703, 2019. doi:10.1016/j.evalprogplan.2019.101703.
8. A. Gupta and D. Zhdanov, "Growth and Sustainability of Managed Security Services Networks: An Economic Perspective," *MIS Quarterly*, vol. 36, no. 4, pp. 1109–1130, 2012.
9. D. Wu et al., "Decision making in information security outsourcing: Impact of complementary and substitutable firms," *Computers & Industrial Engineering*, vol. 110, pp. 1–12, 2017. doi:10.1016/j.cie.2017.05.018.

10. V. Maliene, R. Dixon-Gough, and N. Malys, "Dispersion of relative importance values contributes to the ranking uncertainty: Sensitivity analysis of Multiple Criteria Decision-Making methods," *Applied Soft Computing*, vol. 67, pp. 286–298, 2018. doi:10.1016/j.asoc.2018.03.003.
11. A. Cezar, H. Cavusoglu, and S. Raghunathan, "Sourcing Information Security Operations: The Role of Risk Interdependency and Competitive Externality in Outsourcing Decisions," *Production and Operations Management*, vol. 26, no. 5, pp. 860–879, 2017. doi:10.1111/poms.12681.
12. S. G. Powell, K. R. Baker, and B. Lawson, "A critical review of the literature on spreadsheet errors," *Decision Support Systems*, vol. 46, no. 1, pp. 128–138, 2008. doi:10.1016/j.dss.2008.06.001.
13. P.-L. Poon, M. F. Lau, Y. T. Yu, and S.-F. Tang, "Spreadsheet quality assurance: a literature review," *Frontiers of Computer Science*, vol. 18, article 182203, 2024. doi:10.1007/s11704-023-2384-6.
14. N. Dawson, E. Knight, I. Bongiovanni, and R. O'Quinn, "Informed cybersecurity decisions: A synthesis of expert perspectives," *Computers & Security*, vol. 167, article 104927, 2026. doi:10.1016/j.cose.2026.104927.
15. Assurance Case Working Group, *Goal Structuring Notation Community Standard*, Version 3, Safety-Critical Systems Club, 2021. https://scsc.uk/resources/citation_r1386.html.
16. Object Management Group, *Structured Assurance Case Metamodel*, Version 2.3, October 2023. https://www.omg.org/spec/SACM/2.3.
17. M. Mohamad, J.-P. Steghöfer, and R. Scandariato, "Security assurance cases—state of the art of an emerging approach," *Empirical Software Engineering*, vol. 26, article 70, 2021. doi:10.1007/s10664-021-09971-7.
18. M. Mohamad, J.-P. Steghöfer, E. Knauss, and R. Scandariato, "Managing security evidence in safety-critical organizations," *Journal of Systems and Software*, vol. 214, article 112082, 2024. doi:10.1016/j.jss.2024.112082.
19. T. Viger et al., "Assessing the Usefulness of Assurance Cases: Experience With the Large Hadron Collider," *Systems Engineering*, vol. 29, no. 1, pp. 99–113, 2026. doi:10.1002/sys.70010.
20. C. F. Manski, "Partial identification with missing data: Concepts and findings," *International Journal of Approximate Reasoning*, vol. 39, no. 2–3, pp. 151–165, 2005. doi:10.1016/j.ijar.2004.10.006.
21. National Institute of Standards and Technology, "OSCAL Control Mapping Model," OSCAL Control Layer, accessed November 2026. https://pages.nist.gov/OSCAL/learn/concepts/layer/control/mapping/.
22. National Institute of Standards and Technology, "OSCAL Assessment Results Model," OSCAL Assessment Layer, accessed 2026.
23. National Institute of Standards and Technology, "OSCAL System Security Plan Model v1.2.3: implementation-status," OSCAL Reference, accessed 2026.
24. K. Schroeder, H. Trinh, and V. Pillitteri, *Measurement Guide for Information Security, Vol. 1: Identifying and Selecting Measures*, NIST SP 800-55 Vol. 1, 2024. doi:10.6028/NIST.SP.800-55v1.
25. K. Schroeder, H. Trinh, and V. Pillitteri, *Measurement Guide for Information Security, Vol. 2: Developing an Information Security Measurement Program*, NIST SP 800-55 Vol. 2, 2024. doi:10.6028/NIST.SP.800-55v2.
26. K. Scarfone, M. Souppaya, and M. Fagan, *Mapping Relationships Between Documentary Standards, Regulations, Frameworks, and Guidelines*, NIST IR 8477, 2024. doi:10.6028/NIST.IR.8477.
27. S. Quinn, D. Eliot, G. Witte, and B. Hoehn, *NIST Cybersecurity Framework 2.0: Informative References Quick-Start Guide*, NIST SP 1347, August 2026. doi:10.6028/NIST.SP.1347.
28. B. Kocaoglu, "A Process-Level Digital Maturity and Roadmapping Artifact for Purchasing: Development and Utility Demonstration of DEMA," *Systems*, vol. 14, no. 5, article 532, 2026. doi:10.3390/systems14050532.
29. M. Plevnik, "Communication and Information Systems User Support as a Governance Mechanism in a High-Security Public Organization," *Systems*, vol. 14, no. 3, article 288, 2026. doi:10.3390/systems14030288.
30. S. Fowler, K. Joiner, and S. Ma, "Cyber Evaluation and Management Toolkit (CEMT): Face Validity of Model-Based Cybersecurity Decision Making," *Systems*, vol. 12, no. 7, article 238, 2024. doi:10.3390/systems12070238.
31. Y. Chen, X. Liang, X. Xu, and C. Cao, "From Traceability to Closed-Loop Accountability: A Stackelberg Model of Evidence Quality and Recycling Compliance for Emerging Electric-Vehicle Battery Digital Identity Governance," *Systems*, vol. 14, no. 9, article 1038, 2026. doi:10.3390/systems14091038.